

Active Directory Lab Setup

Report

Submitted by
Ajay Chandran M

05 March 2025

Kozhikode

Table of Contents

1. LAB SETUP	3
1.1 Overview	3
1.2 Network Topology	3
1.3 Machines & Roles.....	4
2. CONFIGURATIONS.....	5
2.1 Disabled Windows Defender and Firewall	5
2.2 Enabled RDP Access	7
2.3 Always Install with Elevated Privileges	7
2.4 Anonymous Access to RPC Services.....	8
2.5 WinRM Configuration.....	8
2.6 Set Weak Password.....	9
2.7 Disabled Kerberos Pre-authentication.....	9
2.8 Passwords in Description.....	10
2.9 Storing Sensitive Files	10
2.10 Creation of a Service Account.....	11

1. LAB SETUP

1.1 Overview

This report documents the setup of an Active Directory lab environment. The purpose of this lab is to understand AD configurations, test security vulnerabilities, and explore attack techniques in a controlled environment.

1.2 Network Topology

The lab consists of a domain controller, two Windows 10 clients, and a Kali Linux machine. The network is configured as follows:

- **Domain Controller (DC1)** – Windows Server 2019
- **Client 1 (C1)** – Windows 10 Enterprise
- **Client 2 (C2)** – Windows 10 Enterprise
- **Attacker Machine** – Kali Linux

IP Configuration:

- **DC1:** 10.0.3.7 (Active) / 192.168.20.7 (Disabled for direct attacks)
- **C1** : 10.0.3.8 & 192.168.20.8, domain-joined
- **C2** : 10.0.3.9 & 192.168.20.9, domain-joined
- **Kali** : 192.168.20.30 (can only reach DC1 via C1 or C2)

This setup ensures that attacks must be routed through a compromised client rather than directly attacking the domain controller.

1.3 Machines & Roles

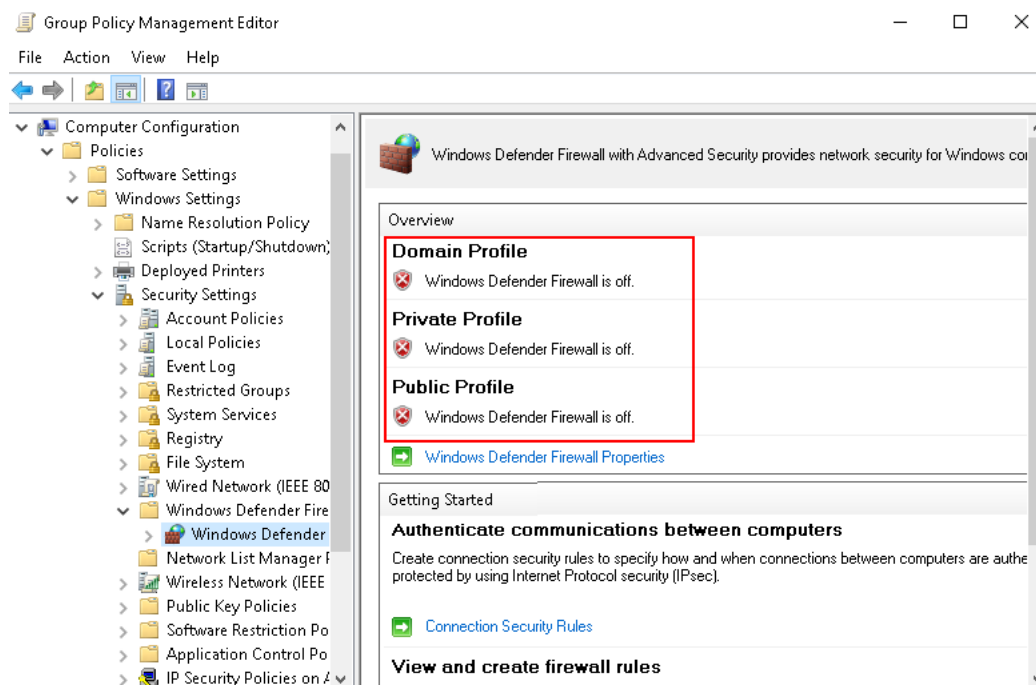
- **DC1 (Domain Controller):**
 - Hosts Active Directory services
 - Manages domain authentication
 - Enforces Group Policy settings
- **C1 & C2 (Windows Clients):**
 - Joined to the domain
 - Used for user authentication and lateral movement tests
- **Kali Linux (Attacker Machine):**
 - Used for penetration testing and attack simulations

2. CONFIGURATIONS

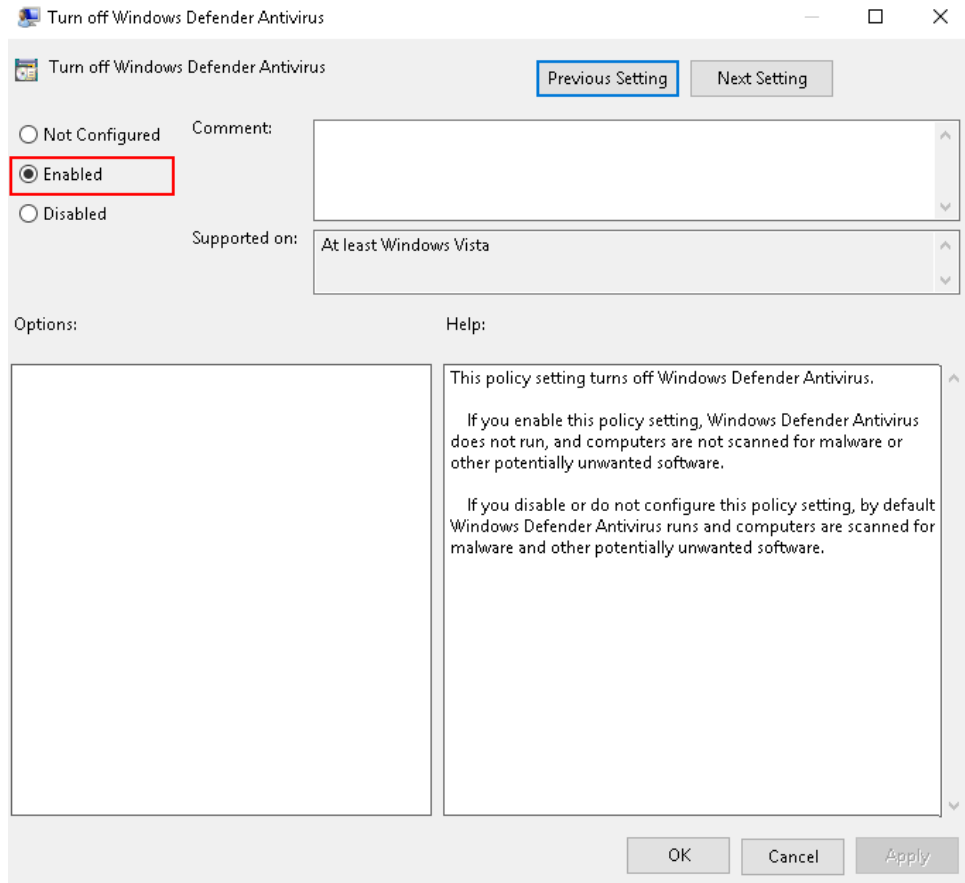
This section explains the key configurations applied in the AD lab.

2.1 Disabled Windows Defender and Firewall

- Allows security testing without interference from built-in security mechanisms.
- Steps to turn off Firewall:
 1. Open **Group Policy Manager**, create a GPO, click edit, go to:
Computer Configuration → Policies → Windows Settings → Security Settings → Windows Defender Firewall with Advanced Security
 2. Right-click on "Windows Defender Firewall with Advanced Security" → Select Properties.
 3. For Domain Profile, Private Profile, and Public Profile: Set Firewall state to Off. Click Apply and OK.

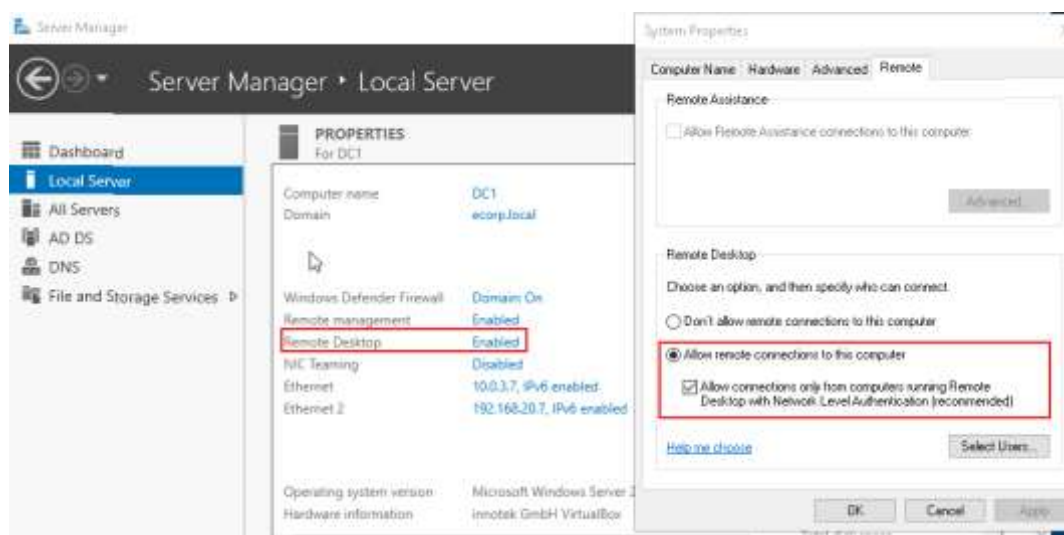


- Steps to turn off Windows Defender:
 1. Edit the GPO, go to: Computer Configuration → Policies → Administrative Templates → Windows Components → Windows Defender Antivirus
 2. Double-click: Turn off Microsoft Defender Antivirus → Set to Enabled → Click OK.



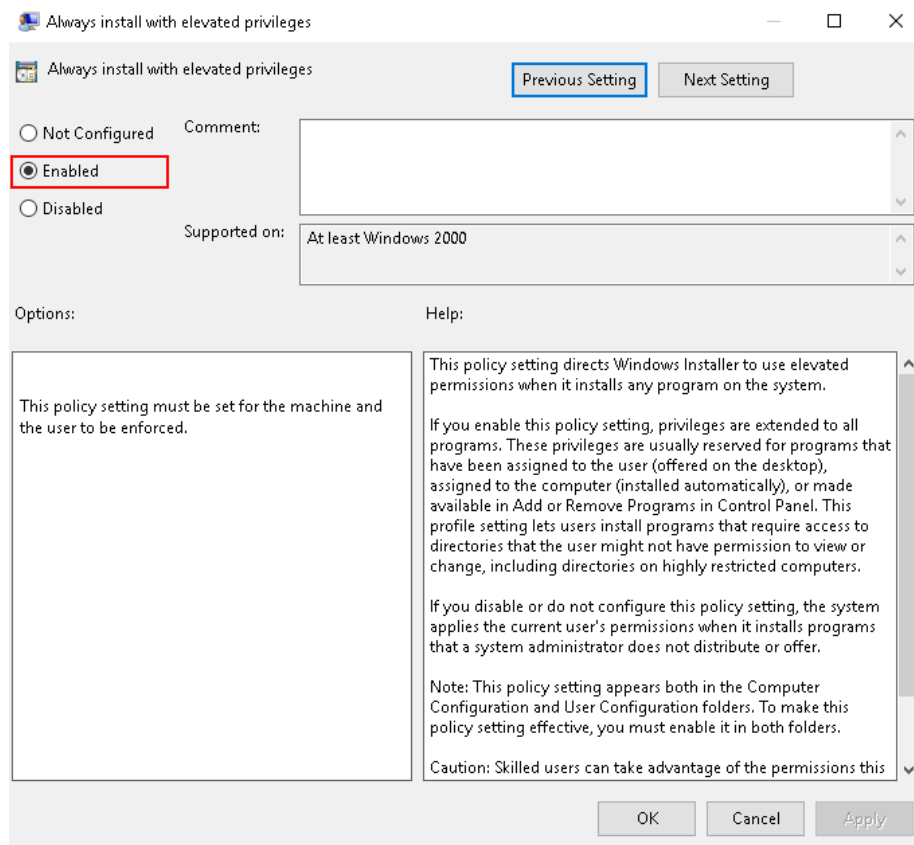
2.2 Enabled RDP Access

- Allows remote access to domain machines for testing.
- Steps:
 1. Open **Server Manager**.
 2. Click **Local Server** (on the left pane).
 3. Look for **Remote Desktop** in the **Properties** section.
 4. Click **Disabled**, then select **Allow remote connections to this computer**.
 5. Click **Apply** and **OK**.



2.3 Always Install with Elevated Privileges

- This allows non-admins to install MSI packages with SYSTEM privileges
- Steps:
 1. Open Group Policy Management
 2. Right click Domain > Create a GPO in this domain then edit.
 3. Navigate to: Computer Configuration → Policies → Administrative Templates → Windows Components → Windows Installer
 4. Set "**Always install with elevated privileges**" → **Enabled**
 5. Navigate to: User Configuration → Policies → Administrative Templates → Windows Components → Windows Installer
 6. Set "**Always install with elevated privileges**" → **Enabled**



2.4 Anonymous Access to RPC Services

- Allows enumeration of RPC services without authentication, a common misconfiguration.
- **Enable Guest Account:** Activate the Guest account via **Computer Management** or use `net user Guest /active:yes`. Leave the password blank.
- **Allow Anonymous RPC Access:** Modify registry values (`RestrictAnonymous = 0`, `RestrictAnonymousSAM = 0`) under `HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa` and restart the server.

2.5 WinRM Configuration

- WinRM (Windows Remote Management) is a Microsoft protocol that allows remote command execution and system management using SOAP-based communication.
- Exploited using Evil-winrm

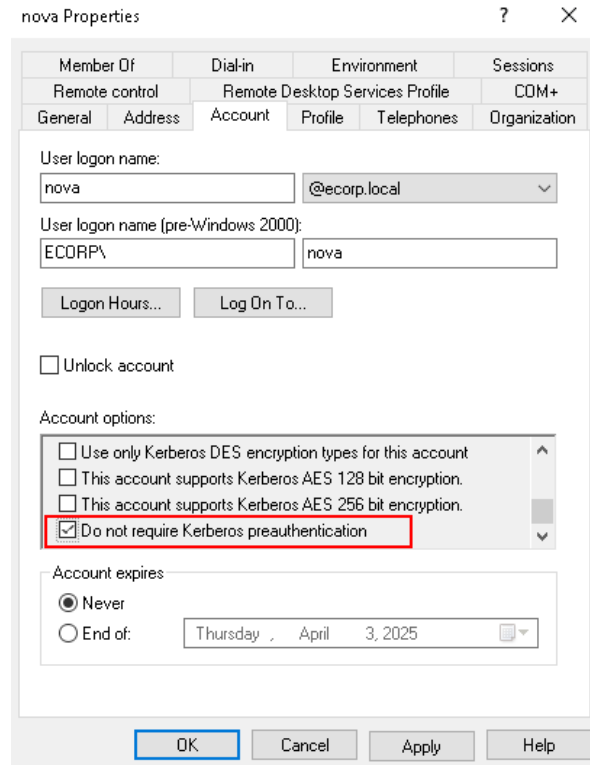
- Steps:
 - Inside C1, open PowerShell (Admin) and run “winrm quickconfig”
 - Set network to Private:
Set-NetConnectionProfile -NetworkCategory Private
 - Add **Jack**(domain user) to Remote Management Users (powershell) :
net localgroup "Remote Management Users" Ecorp\jack /add

2.6 Set Weak Password

- Simulates weak password practices for testing credential theft.
- Setting passwords that can brute forced easily (example: Password1, 12345678, user@123)
- Exploited in LLMNR Poisoning

2.7 Disabled Kerberos Pre-authentication

- Disabled kerberos pre-authentication for a user account
- Allows attackers to request encrypted AS-REP messages for offline brute force attacks.
- Exploited in AS-REP Roasting



2.8 Passwords in Description

- Added passwords in Description when creating accounts
- Demonstrates poor password storage practices that can be exploited.
- Exploited in PowerView Enumeration

The screenshot shows the 'nova Properties' dialog box with the 'General' tab selected. The 'Description' field is highlighted with a red box and contains the text 'Password@1'. The 'First name' field contains 'nova' and the 'Display name' field also contains 'nova'. The 'Last name' field is empty. The 'Office' field is empty. The 'Telephone number' field is empty with an 'Other...' button next to it. The 'E-mail' field is empty. The 'Web page' field is empty with an 'Other...' button next to it. The 'OK' button is highlighted with a blue border.

2.9 Storing Sensitive Files

- Simulates poor security practices by saving domain admin credentials in a file.
- Domain admin saves his login creds in a file (C:\Users\Nova\secret.txt in C1)
- which can be retrieved after compromising C1 (NT Authority is required to access domain admin folders)

2.10 Creation of a Service Account

- Service accounts are often misconfigured, leading to privilege escalation risks.
- Exploited in silver ticket attack
- Steps:
 1. Create a User in AD (e.g., svc-sqlserver)
 2. Assign an SPN to the User:
`setspn -A MSSQLSvc/DC1.ecorp.local:1433 ecorp\svc-sqlserver`
 3. Verify SPN:
`setspn -L ecorp\svc-sqlserver`

```
PS C:\Users\Administrator> setspn -A MSSQLSvc/DC1.ecorp.local:1433 ecorp\svc-sqlserver
Checking domain DC=ecorp,DC=local

Registering ServicePrincipalNames for CN=svc-sqlserver,CN=Users,DC=ecorp,DC=local
MSSQLSvc/DC1.ecorp.local:1433
Updated object
PS C:\Users\Administrator> setspn -L ecorp\svc-sqlserver
Registered ServicePrincipalNames for CN=svc-sqlserver,CN=Users,DC=ecorp,DC=local:
MSSQLSvc/DC1.ecorp.local:1433
PS C:\Users\Administrator>
```